

AOPS Production Control Research

28 July 2026 • 40 Sources

40

REGISTERED SOURCES

24

CAPTURED EVIDENCE SPANS

16

CRITICAL CLAIMS TRACED

0

UNSUPPORTED FACTUAL CLAIMS

EXECUTIVE SUMMARY

AOPS should be built as a provider-neutral organizational authority, execution, accounting, and evidence system rather than as another agent wallet or payment-protocol wrapper. Circle, x402, MPP, AP2, and card networks are rapidly providing wallets, payment challenges, mandate artifacts, agent tokens, settlement, and service discovery. Circle's Agent Stack now combines agent wallets, spending controls, x402 discovery, Nanopayments, and multichain operations [33]. x402 defines a direct HTTP payment challenge and resubmission flow [34], while MPP supports machine-addressable resources across more payment methods [36][37]. AP2 and Visa focus on binding authenticated user instructions to checkout/payment credentials and receipts [38][39]. These developments reduce the defensibility of basic spend-limit or payment-wrapper products.

The durable AOPS opportunity is the layer above those rails: organization and workload identity, attenuated delegation, mission-scoped authority, deterministic policy, human approvals, reservation-backed budgets, provider-neutral execution, double-entry accounting, explicit recovery from uncertain external outcomes, and exportable evidence. This layer must preserve rail-specific semantics instead of forcing every provider into a false universal lifecycle.

The most important production conclusion is that readiness is not a single product status. A release is safe only for a specific core, execution profile, and market/tenant/use-case tuple. A financial execution profile additionally pins its adapter, provider, network, asset, and signer. External payments are asynchronous and may return an unclear result; Circle explicitly separates submission from finalization [11][12], while Gateway webhooks can be duplicated and delivered out of order [13]. Therefore AOPS must persist durable intent before external submission, reserve

authority and money, maintain an explicit unknown state, use authoritative lookup, and reconcile into append-only double-entry accounting.

Evidence is a product subsystem, not logging. It must reconstruct the chain from accountable principal through mandate, policy, approval, reservation, execution, external outcome, ledger, and reconciliation. Privacy requires immutable proof metadata to remain separate from erasable personal or sensitive payload. Production claims must be backed by fresh artifacts pinned to the exact release and profile.

INTRODUCTION

This research examines what AOPS must become to support real organizations operating fleets of autonomous agents that perform operational and financial work. The scope includes identity, delegation, missions, policies, approvals, runtime mediation, provider/service commerce, treasury, signing, payment adapters, accounting, evidence, privacy, operational resilience, and Circle/Arc integration.

The analysis distinguishes three evidence classes. First, official standards and regulator materials define security, privacy, identity, and assurance constraints. Second, official provider and protocol documentation defines current external capability and behavior. Third, exact local source inspection defines what AOPS currently implements. Prior strategy and architecture documents are treated as design inputs, not proof.

The main assumption is that AOPS will initially remain a domain-first modular system rather than immediately decomposing into many microservices. This preserves transactional clarity and reduces operational overhead while still enforcing domain ownership, versioned interfaces, and independently testable boundaries. A second assumption is that the first real-money release will use one narrow business-to-business service-purchase profile and one supported Circle mainnet path. Arc is treated separately because Arc's official deployment documentation identifies Public Testnet as the current active network [14].

MAIN ANALYSIS

Finding 1: Payment primitives are expanding, but organizational control remains fragmented

Circle's official Agent Stack already lets agents operate wallets, transact onchain, discover and pay x402 services, use configurable wallet spending policies, and make Gateway-powered Nanopayments [33]. This means AOPS cannot position basic wallet creation, per-transaction caps, or x402 payment as a complete differentiated product. Those are increasingly provider primitives.

x402 defines a client/server flow where a service returns 402 Payment Required, the client constructs a signed payment payload, and the request is resubmitted [34]. The current x402 documentation also distinguishes protocol versions and recommends v2 [35]. MPP broadens the machine-payment surface: Stripe documents agent-paid resources, stablecoin and card-related methods, refunds, and settlement into ordinary Stripe balances [36], while the protocol announcement describes resources at services, APIs, MCP endpoints, or other HTTP addresses [37].

Mandate-oriented systems address a different part of the problem. AP2 defines checkout and payment mandates, exact schema versions, human-present and autonomous modes, cryptographic bindings, receipts, and dispute verification [38]. Visa Intelligent Commerce describes agent-specific tokens, passkey-authenticated user instructions, credential requests bound to those instructions, network controls, and outcome signals [39]. Mastercard has separately introduced agentic tokens as part of Agent Pay [40].

These systems are not interchangeable. x402 and MPP focus on resource/payment negotiation; AP2 and card networks focus on user intent, credentials, checkout, authorization, and disputes; Circle provides wallet and settlement primitives. AOPS should map each into stable organizational objects without pretending their external state machines are identical.

The stable AOPS value is that an organization can define who an agent is, what mission it serves, which authority it inherited, how approval and budget apply across providers, what happened when execution failed, and what evidence survives afterward. This is a control and assurance problem spanning operations and finance, not merely a payment-method problem.

Finding 2: Identity must model both human accountability and workload delegation

Zero-trust guidance moves authorization away from implicit network position and toward identity-specific access decisions [2]. OAuth security guidance recommends restricting access tokens to the intended resources and actions [3]. MCP security guidance forbids token passthrough because accepting a token issued for another resource creates confused-deputy and audience-validation failures [4].

For AOPS, this means a human login, agent API key, and wallet address cannot collapse into one generic “user.” The system needs human principals, organization membership, workload principals, agent hierarchy, runtime connections, human sponsorship, and explicit delegation. The delegation must preserve both subject and actor, allowed resources/actions, budget, expiry, and child-delegation depth. A parent-child pointer is not authority.

Privileged human access should use phishing-resistant authentication and separation of duties. NIST’s current authentication guidance requires two factors at AAL2 and a phishing-resistant option, while higher assurance uses non-exportable keys [22]. AOPS need not claim formal federal assurance levels, but it can adopt stronger privileged-access requirements as internal policy.

Workload credentials should be short-lived, audience-restricted, tenant-bound, and revocable. Credentials for providers and signers should remain outside prompts and model context. The runtime receives a one-time execution grant or narrow credential reference rather than a reusable provider secret.

Identity failures propagate. Terminating a human sponsor may orphan agents. Revoking a parent delegation affects descendants. Suspending an agent must deny new work without erasing submitted payment attempts that still require reconciliation. Therefore identity state cannot be designed independently from mission, grant, runtime, and financial state.

Finding 3: Exactly-once external execution is not a credible promise

Distributed external systems cannot offer one universal exactly-once guarantee. AWS's idempotency guidance warns that simply retrying an unclear request can create duplicate side effects [9]. PayPal, Stripe, and Adyen each expose idempotency behavior, but their scope and retention semantics are provider-specific [10][23][24].

Circle documents that transaction-like entities are processed asynchronously after the initial request [11]. It separately explains that submitting to a blockchain and reaching finality are distinct events [12]. Gateway webhooks are not guaranteed to arrive in order and may be retried [13]. These are normal conditions, not exotic failures.

The correct AOPS contract is durable intent, idempotent effect where the provider supports it, explicit uncertainty, authoritative lookup, and reconciliation. Before any external request, AOPS records an action intent, request hash, actor, mission, policy, approval/grant, and idempotency identity. Before a financial submission, it holds the required budget and creates the execution attempt. If a timeout occurs after possible provider acceptance, the attempt becomes unknown.

An unknown attempt cannot release its reservation, generate a new attempt with a new key, or report failure. A reconciliation worker uses the original provider identity, idempotency key, transaction reference, signing receipt, webhook, and direct lookup. Only authoritative external failure permits release. Settlement consumes the hold and creates balanced postings. Reversal or refund creates correcting entries.

This model also changes user experience. Operators need an unknown-attempt console that clearly separates known facts, missing facts, exposure, last lookup, next action, and why unsafe retry/release actions are disabled. A product that hides uncertainty behind a generic failed status is not operationally ready.

Finding 4: Treasury counters are insufficient for real-money control

Financial control requires an append-only double-entry ledger. Accounting references emphasize that each economic event records both sides of a movement [25]. Two-phase financial transfers model pending and final dispositions explicitly [26]. PostgreSQL serializable isolation can enforce strong application invariants, but applications must handle serialization failures and retry correctly [27].

AOPS needs accounts for treasury assets, provider/wallet balances, team/mission/agent allocations, reservations, clearing, expenses, fees, refunds, disputes, and reconciliation suspense. Amounts use exact integer units with explicit asset/decimals/network metadata. Every allocation, reservation, settlement, release, fee, refund, reversal, dispute, and correction produces balanced immutable postings.

Reservations are not cosmetic budget counters. They prevent multiple concurrent agents from spending the same remaining authority. Budget utilization is settled consumption plus outstanding holds. A reservation connected to externally executable authorization, dispatching, submission, or an unknown outcome remains held or quarantined until authoritative resolution. A local TTL cannot overrule a still-valid external authorization or unresolved submission.

Reconciliation compares internal attempts and ledger state with provider accounts, wallet/chain transactions, facilitator receipts, and provider delivery/refund state. A production profile requires zero unexplained monetary difference at its certified cutoff. A mismatch opens a case, may stop the affected adapter, and cannot be erased by editing counters.

The ledger also makes audit and recovery possible. After restore, the system rebuilds projections from immutable entries, verifies balances, recovers reservations and attempts, and reconciles before money reopens. Without this, “budget control” remains an application feature rather than a financial control system.

Finding 5: Evidence must be complete, independently verifiable, and privacy-aware

NIST incident guidance calls for recording investigative actions while preserving record integrity and provenance [6]. The AICPA Trust Services Criteria span security, availability, processing integrity, confidentiality, and privacy [19]. These frameworks do not certify AOPS by themselves, but they show why an internal activity feed is not sufficient assurance.

An AOPS evidence bundle must reconstruct principal, delegation, mission, policy, approval/grant, reservation, signer, execution attempt, external outcome, provider delivery, ledger posting, reconciliation, and incident disposition. It must pin the exact source/build/migration/schema/adapter/market profile. Verification must detect content modification, insertion, gaps, forks, head replacement, and tail truncation.

The integrity mechanism must also survive an application/database administrator attack. If the same administrator can rewrite both events and the chain head, the mechanism is only internally tamper-evident. Production options include signed external checkpoints, an independent append-only/WORM store, a transparency log, or a nonpersonal onchain digest.

Privacy prevents simply anchoring complete records onchain. The EDPB cautions that storing personal data on a blockchain should generally be avoided where it conflicts with data-protection principles [17]. GDPR requires purpose limitation, minimization, storage limitation, security, and applicable erasure [18].

AOPS must therefore separate immutable pseudonymous metadata and digests from encrypted erasable payload.

Deletion workflows must reach primary databases, search, object stores, caches, analytics, exports, replicas, and backup expiry. Legal hold must be explicitly scoped and authorized. After eligible payload deletion, a reviewer should still be able to verify that a correctly authorized event existed without retaining prohibited content.

Finding 6: Production readiness is a continuously revocable profile

The NIST Secure Software Development Framework is intended as a risk-based foundation rather than a checklist [5]. SLSA focuses on artifact provenance and supply-chain integrity [28]. Google's SRE guidance defines service-level objectives as target reliability for user-facing service behavior [8]. NIST contingency planning and incident guidance require preparation, recovery, and evidence-preserving response [6][7].

For AOPS, production readiness should therefore be encoded as one composite release certificate binding three independently evaluated results: Core, execution profile, and market/tenant/use case. The Core gate result proves identity, authority, ledger, evidence, and recovery. A runtime execution-profile result proves the exact mediated/controlled path and bypass boundary. A financial execution-profile result proves provider-specific idempotency, state mapping, webhook, lookup, finality, refund/dispute, signer, and mainnet-canary behavior. The market eligibility result proves entity, jurisdiction, provider eligibility, data, custody, terms, and use-case boundaries. None of the component results enables production by itself.

Each certificate expires and is revoked immediately after material changes. Changes include policy or ledger schema, signer/KMS, provider API, webhook schema, facilitator, network, chain, contract, asset, retention behavior, or deployment/restore model. Revocation pauses new authority while preserving controlled resolution of in-flight work.

Operational SLOs should measure correct authorization, reservation/ledger availability, duplicate-free economic execution, unknown-resolution latency, reconciliation freshness, evidence completeness, revocation propagation, and operator intervention—not only API uptime. Error-budget exhaustion should stop limit increases and may disable money traffic.

The release process ends with a low-limit mainnet canary for the exact adapter and signer profile, direct verification against external truth, ledger reconciliation, independent evidence verification, and staged limit increases. Testnet proof remains valuable but cannot certify mainnet.

SYNTHESIS AND INSIGHTS

The product architecture follows from one central insight: authority, execution, money, delivery, and proof are different state machines. Competitors or providers may supply one or several of them, but AOPS creates value by preserving their relationships across an organization and agent fleet.

This implies that payment adapters are not the foundation. The foundation is the canonical control kernel: organization and workload identities, missions, policies, decisions, approvals, grants, reservations, attempts, ledger entries, reconciliation, and evidence. Adapters translate external rails into that kernel without erasing provider-specific behavior.

It also implies that audit is not a report generated after execution. Evidence completeness is a runtime and release invariant. If a financial journey cannot be reconstructed, the system has lost control even if funds appear correct. Conversely, a perfect log cannot make an unsafe payment flow safe; evidence and execution controls must reinforce each other.

Finally, AOPS should avoid claiming universal enforcement. Enforcement is profile-specific. An MCP-mediated call can still be bypassed if the agent retains the native provider credential. A signing path can be hard-enforced when AOPS or a customer-controlled trusted boundary owns the only signing authority. Product language should state exactly which path is advisory, mediated, controlled, or network-enforced.

CLAIMS-EVIDENCE TABLE

The machine-readable claim ledger is `research/claims.jsonl`. This table lists the claims that materially constrain the architecture and release plan.

Claim	Evidence	Architectural consequence
External payment operations can remain asynchronous after initial submission.	Circle transaction states [11] and signing lifecycle [12]	Submission and finality are separate states; timeout after submit becomes unknown.
Gateway webhooks can be duplicated and delivered out of order.	Circle Gateway webhooks [13]	Webhooks are evidence inputs, not sole truth; consumers are idempotent and reconcile through lookup.
Blind retry after an unclear response can duplicate side effects.	AWS idempotency guidance [9] and PayPal guidance [10]	The original durable attempt and provider idempotency identity are reused.
Agent credentials must be resource/action restricted, and MCP token passthrough is forbidden.	RFC 9700 [3] and MCP security guidance [4]	Runtime credentials are audience-bound and provider secrets never pass through model context.
Circle already supplies agent wallets and x402 payment primitives.	Circle Agent Stack [33]	AOPS differentiates above wallet/payment primitives through organization, mission, authority, recovery, and evidence.
x402, MPP, AP2, and card-network flows expose different control objects.	x402 [34], MPP [36][37], AP2 [38], Visa [39], Mastercard [40]	A provider-neutral core is paired with adapter-specific state machines rather than one false universal payment lifecycle.

Claim	Evidence	Architectural consequence
Arc Public Testnet is the current active Arc network.	Arc deployment model [14]	Arc remains an independently certified testnet profile; no Arc-mainnet claim is permitted.
Personal data should not be made immutable where that conflicts with data-protection principles.	EDPB blockchain guidance [17] and GDPR [18]	Immutable digests and erasable encrypted payload are separated.
Financial effects require balanced, immutable accounting and explicit pending states.	TigerBeetle accounting and two-phase transfers [25][26]	Reservations, settlement, fees, refunds, reversals, and corrections become double-entry postings.
Production assurance is risk-based and evidence must preserve integrity and provenance.	NIST SSDF [5] and incident-response guidance [6]	Certification is a revocable evidence manifest, not a static checklist or prose claim.

COUNTEREVIDENCE REGISTER

Attractive claim	Counterevidence or constraint	Treatment in this corpus
“AOPS is differentiated because it gives agents wallets and spend limits.”	Circle Agent Stack already exposes wallets, x402 payments, and wallet spending policies [33].	Wallet primitives are adapters; the product kernel is organizational authority, recovery, accounting, and proof.
“One normalized payment state machine can cover every rail.”	x402, MPP, AP2, card networks, and onchain transactions expose different mandate, authorization, delivery, refund, finality, and dispute semantics [34][36][38][39].	The kernel normalizes control identities and evidence links, while adapters retain rail-specific states.
“A successful API response means the action is final.”	Circle separates initial processing, blockchain submission, and finality [11][12]; webhooks may be duplicated or reordered [13].	External status remains provisional until authoritative reconciliation.
“Retries make transient errors harmless.”	Retrying an unclear request can duplicate side effects [9]. Provider idempotency scope and retention vary [10][23][24].	Retry is permitted only against the same durable attempt under adapter-certified semantics.
“MCP mediation alone guarantees enforcement.”	MCP security guidance addresses authorization, but an agent holding a native provider credential can bypass an optional mediator [4].	Each profile declares its enforcement strength; bypassable paths are excluded or disabled.
“Onchain evidence should contain the complete audit record.”	EDPB guidance warns against storing personal data on blockchains where incompatible with data-protection principles [17].	Only nonpersonal digests/checkpoints may be immutable; sensitive payload remains encrypted and erasable.
“Passing a testnet run certifies mainnet.”	Networks, providers, signer profiles, assets, and finality behavior are profile-	Testnet and mainnet certificates are distinct and non-transitive.

Attractive claim	Counterevidence or constraint	Treatment in this corpus
	specific; Arc currently identifies Public Testnet as active [14].	
“Mapping controls to standards makes the product compliant.”	SSDF is a risk-based foundation rather than a checklist [5]; external assurance and legal scope remain separate.	The corpus claims internal readiness evidence only, never certification or legal compliance without the required external process.

LIMITATIONS AND CAVEATS

Provider and protocol capabilities change quickly. Circle, Arc, x402, MPP, AP2, Visa, and Mastercard facts must be reverified against official documentation before implementation and before every certificate issuance. Several card-network products may require partnership access and may not expose complete public production APIs.

This research does not determine the legal classification of AOPS, custody, payment-services obligations, sanctions responsibilities, tax treatment, or market eligibility. Those require qualified legal review for the exact entity, customer, provider, jurisdiction, and use case.

The recommended internal security and freshness thresholds are AOPS product policy. They are not claimed as mandatory language from the referenced standards. External attestation remains separate.

The exact-code audit identified current gaps but did not rerun the full test suite during the planning pass. Previously recorded checkpoint evidence is preserved as a distinct artifact and must not be generalized to mainnet production.

RECOMMENDATIONS

First, complete Phase 0 safety corrections: move all external egress behind durable intent and policy, design the default-deny migration, complete unknown-state reconciliation, and repair audit tail verification. These changes prevent current behavior from hardening into the new architecture.

Second, implement the canonical state/event/evidence substrate before adding more payment rails. Then complete IAM, workload identity, missions, policy, approvals/grants, runtime mediation, double-entry ledger, signing, evidence/privacy, and platform recovery as a provider-neutral Production Core.

Third, choose one narrow Circle-supported mainnet adapter and one B2B paid-service use case. Resolve custody/wallet topology through an explicit ADR and measurable maximum-loss analysis. Pass sandbox, testnet, fault-injection, restore, and conformance gates before a low-limit mainnet canary.

Fourth, build the Arc Public Testnet profile using the same core and adapter contract. Demonstrate real Arc settlement, denial, approval, failure-safe recovery, reconciliation, and evidence without claiming Arc

mainnet.

Fifth, expand x402, MPP, AP2/card, and other provider profiles through the adapter factory only after the first production tuple is proven. Every profile remains independently certifiable and revocable.

METHODOLOGY APPENDIX

The research followed a deep multi-source process. Scope covered current AOPS code boundaries, official Circle/Arc capabilities, agent-payment protocols, identity/authorization standards, idempotency, financial accounting, privacy, secure development, and operations.

The local codebase and existing product research were inspected first to identify the exact questions and contradictions. Official sources were then collected and registered with stable source IDs. Evidence spans were persisted in `research/evidence.jsonl`, while `research/sources.jsonl` records canonical locators. Major claims were triangulated across provider documentation, standards, regulator guidance, and independent engineering references.

Three independent review tracks covered current-document inventory, domain/dependency design, and production red-team analysis. One attempted external Gemini review was rejected by the tool’s data-risk boundary, so no Gemini output was used.

The evidence changed the outline in two material ways. First, the planning model moved from “complete each domain” to a combination of domain ownership and cross-domain journey certification because failures occur at seams. Second, Arc was separated into a Public Testnet profile rather than used as the initial real-money mainnet target because official deployment documentation identifies Public Testnet as current.

Limitations, unsupported claims, unresolved ADRs, current-code boundaries, and test evidence boundaries are recorded explicitly in this corpus.

BIBLIOGRAPHY

- [1] NIST NCCoE (2026). “Software and AI Agent Identity and Authorization Concept Paper.”
- [2] NIST (2023). “SP 800-207A — Zero Trust Architecture Model for Access Control in Cloud-Native Applications.”
- [3] IETF (2025). “RFC 9700 — Best Current Practice for OAuth 2.0 Security.”

- [4]** Model Context Protocol (2026). “Security Best Practices.”
- [5]** NIST (2022). “Secure Software Development Framework.”
- [6]** NIST (2025). “SP 800-61 Rev. 3 — Incident Response Recommendations and Considerations for Cybersecurity Risk Management.”
- [7]** NIST (2010). “SP 800-34 Rev. 1 — Contingency Planning Guide for Federal Information Systems.”
- [8]** Google SRE (2018). “Implementing SLOs.”
- [9]** AWS Builders Library (2021). “Making Retries Safe with Idempotent APIs.”
- [10]** PayPal (2026). “Idempotency Guidelines.”
- [11]** Circle (2026). “Wallet Transaction States and Errors.”
- [12]** Circle (2026). “Wallet Signing and Authorization Models.”
- [13]** Circle (2026). “Gateway Webhooks.”
- [14]** Arc (2026). “Network Deployment Model.”
- [15]** Circle (2026). “Gateway Supported Blockchains.”
- [16]** Circle (2026). “Wallets Supported Blockchains.”
- [17]** European Data Protection Board (2026). “Guidelines on Processing of Personal Data through Blockchain Technologies.”
- [18]** European Union (2016). “General Data Protection Regulation.”
- [19]** AICPA (2022). “Trust Services Criteria.”
- [20]** PCI Security Standards Council (2026). “PCI DSS Document Library.”
- [21]** IETF (2020). “RFC 8693 — OAuth 2.0 Token Exchange.”
- [22]** NIST (2025). “SP 800-63B-4 — Authentication and Authenticator Management.”
- [23]** Stripe (2026). “Idempotent Requests.”
- [24]** Adyen (2026). “API Idempotency.”
- [25]** TigerBeetle (2026). “Financial Accounting.”
- [26]** TigerBeetle (2026). “Two-Phase Transfers.”
- [27]** PostgreSQL (2026). “Transaction Isolation.”

- [28]** SLSA (2026). “SLSA v1.2 Requirements.”
- [29]** ISO (2022). “ISO/IEC 27001 — Information Security Management Systems.”
- [30]** OWASP (2025). “Top 10 for Agentic Applications.”
- [31]** OWASP (2026). “AI Agent Security Cheat Sheet.”
- [32]** IETF (2015). “RFC 7644 — SCIM Protocol.”
- [33]** Circle (2026). “Agent Stack.”
- [34]** Coinbase Developer Platform (2026). “x402 Client and Server Flow.”
- [35]** Coinbase Developer Platform (2026). “x402 v1 to v2 Migration Guide.”
- [36]** Stripe (2026). “Machine Payments.”
- [37]** Stripe and Tempo (2026). “Introducing the Machine Payments Protocol.”
- [38]** AP2 Project (2026). “Agent Payments Protocol Specification.”
- [39]** Visa (2026). “Visa Intelligent Commerce.”
- [40]** Mastercard (2025). “Mastercard Agent Pay.”